

Security+ 1.4 · Certificates

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Certificates (14:38)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Certificado digital: arquivo assinado pela CA (Certificate Authority) que liga domínio a chave pública. Self-signed = tu mesmo assina (confiança própria, não deve ir pro público). CSR = Certificate Signing Request (tu manda a chave pública + identidade pra CA assinar). CRL (lista de revogados) / OCSP (verificação online) / OCSP stapling (servidor anexa resposta).

Highlights que a prova cobra

- CA assina o certificado — cadeia de confiança root CA → intermediária → leaf
- CSR = requisição de assinatura: contém a chave pública + identidade
- CRL/OCSP/stapling = como o browser checa se certificado foi revogado

Dicas de prova & Cenários Típicos

- 'contains public key and identity, signed by CA' = certificate
- 'revocation checking method with online query' = OCSP

Cenário clássico de exame: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revogado.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.4 — Certificates)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. No TLS/HTTPS, o certificado do site serve pra:

- A)** Provar a identidade do servidor e habilitar a troca segura de chave
- B)** Criptografar o disco
- C)** Bloquear malware
- D)** Fazer backup

2. Em uma infraestrutura PKI, qual componente é responsável por validar e revogar certificados digitais?

- A)** RA (Registration Authority)
- B)** CA (Certificate Authority)
- C)** CRL (Certificate Revocation List)
- D)** OCSP (Online Certificate Status Protocol)

3. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

4. Qual tipo de criptografia usa pares de chaves pública e privada?

- A)** Hashing
- B)** Criptografia simétrica
- C)** Criptografia assimétrica
- D)** Steganografia

5. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CA assina o certificado — cadeia de confiança root CA → intermediária → leaf'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CA assina o certificado — cadeia de confiança root CA → intermediária → lea...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CSR = requisição de assinatura: contém a chave pública + identidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CSR = requisição de assinatura: contém a chave pública + identidade...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'CRL/OCSP/stapling = como o browser checa se certificado foi revogado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: CRL/OCSP/stapling = como o browser checa se certificado foi revogado...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'contains public key and identity, signed by CA' = certificate'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'contains public key and identity, signed by CA' = certificate...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'revocation checking method with online query' = OCSP'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'revocation checking method with online query' = OCSP...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Certificates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revocado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado ...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Provar a identidade do servidor e habilitar a troca segura de chave.

✓ **Por que está certa:** No TLS/HTTPS, o certificado digital do servidor (X.509) cumpre duas funções críticas: (1) autenticar a identidade do servidor perante o cliente, pois é emitido por uma Autoridade Certificadora (CA) confiável que assina digitalmente a chave pública do servidor, vinculando-a ao nome de domínio; (2) viabilizar a troca segura de chaves, pois a chave pública contida no certificado é usada pelo cliente para cifrar o segredo pré-master (ou para verificar assinaturas em efêmeros Diffie-Hellman), permitindo que ambas as partes derivem chaves simétricas de sessão sem transmiti-las em claro. Sem o certificado, o cliente não teria garantia de estar falando com o servidor legítimo e não poderia estabelecer um canal confidencial autenticado.

✗ **Por que as outras estão erradas:**

- *Criptografar o disco:* Criptografia de disco (ex.: BitLocker, LUKS, FileVault) é uma técnica de proteção de dados em repouso que cifra setores do armazenamento físico para impedir leitura não autorizada caso o dispositivo seja perdido ou roubado. Ela opera na camada de armazenamento, não na camada de transporte. O certificado TLS/HTTPS atua exclusivamente na camada de sessão/apresentação para proteger dados em trânsito entre cliente e servidor; ele não tem qualquer relação com a cifragem de volumes locais ou remotos.
- *Bloquear malware:* O bloqueio de malware é realizado por soluções de segurança de endpoint (EDR, antivírus), gateways de e-mail, proxies de conteúdo e sistemas de detecção de intrusão, que inspecionam arquivos, tráfego e comportamentos em busca de assinaturas ou anomalias maliciosas. Um certificado TLS apenas prova a identidade do servidor e estabelece um canal cifrado; ele não analisa o conteúdo do tráfego nem impede a execução de código malicioso. Um site malicioso pode perfeitamente possuir um certificado TLS válido, pois a CA valida apenas o controle do domínio, não a intenção do conteúdo.
- *Fazer backup:* Backup é o processo de copiar e armazenar dados em local secundário para recuperação após perda, corrupção ou desastre. Envolve políticas de retenção, agendamento e testes de restauração. O certificado TLS não executa, agenda ou gerencia cópias de dados; sua função é estritamente criptográfica e de autenticação durante o handshake TLS. Confundir certificado com mecanismo de backup ignora completamente o propósito da infraestrutura de chaves públicas (PKI) no contexto de segurança de comunicações.

2) B — CA (Certificate Authority).

✓ **Por que está certa:** A **CA (Certificate Authority)** é o componente central de uma PKI responsável por emitir, validar e revogar certificados digitais. Ela assina digitalmente os certificados, garantindo a autenticidade e integridade das chaves públicas. Além disso, a CA mantém e publica a CRL (Certificate Revocation List) e/ou oferece o serviço OCSP (Online Certificate Status Protocol) para que terceiros possam verificar se um certificado ainda é válido. No syllabus da CompTIA Security+ (SY0-701), a CA é descrita como a entidade de confiança que valida identidades e gerencia o ciclo de vida dos certificados, incluindo a revogação. Portanto, a CA é a resposta exata para 'validar e revogar certificados digitais'.

✗ **Por que as outras estão erradas:**

- *RA (Registration Authority):* A RA (Registration Authority) é uma entidade subordinada à CA que atua como intermediária no processo de registro de usuários. Sua função principal é verificar a identidade do solicitante antes de encaminhar o pedido de certificado à CA, mas ela não emite, valida ou revoga certificados. A RA pode auxiliar na coleta de documentação e na autenticação inicial, porém a decisão final de emissão e revogação é sempre da CA. No contexto da pergunta, a

RA não executa a validação e revogação de certificados, apenas facilita o registro, portanto está incorreta.

- **CRL (Certificate Revocation List):** A CRL é uma lista publicada periodicamente pela CA contendo os números de série dos certificados que foram revogados antes de sua data de expiração. Ela é um mecanismo de consulta para verificar se um certificado está revogado, mas não realiza a validação ou revogação em si. A CRL é um artefato gerado pela CA; ela não toma decisões nem executa ações de revogação. Além disso, a validação de um certificado envolve verificar a assinatura da CA, a cadeia de confiança e a validade temporal, o que não é feito pela CRL. Portanto, CRL é apenas uma ferramenta de consulta, não o componente responsável pela validação e revogação.
- **OCSP (Online Certificate Status Protocol):** O OCSP é um protocolo de consulta em tempo real que permite verificar se um certificado específico foi revogado, consultando diretamente a CA ou um respondedor OCSP. Ele oferece uma alternativa mais ágil que a CRL, mas não é o componente que valida ou revoga certificados; é apenas um serviço de verificação de status. A responsabilidade de emitir, validar e revogar certificados permanece com a CA. O OCSP depende da CA para obter as informações de revogação. Logo, não é a resposta correta para a função de validar e revogar certificados.

3) B — É de mão única (não reversível).

✓ **Por que está certa:** Uma característica fundamental das funções hash criptográficas é serem de mão única (one-way), ou seja, não reversíveis. Isso significa que, a partir do hash, não é possível recuperar a mensagem original. Essa propriedade é conhecida como resistência à pré-imagem. Diferentemente da criptografia, que é reversível com a chave correta, o hash é projetado para ser irreversível. O CompTIA Security+ destaca que funções hash como SHA-256 são usadas para integridade e armazenamento de senhas (com salt), justamente porque não podem ser revertidas. A opção 'É de mão única (não reversível)' descreve corretamente essa característica essencial.

✗ **Por que as outras estão erradas:**

- **Pode ser revertido com a chave:** Essa é uma característica da criptografia simétrica ou assimétrica, não de funções hash. Na criptografia, a reversão é possível com a chave apropriada (simétrica) ou com a chave privada (assimétrica). Funções hash não possuem chave e não são projetadas para reversão. Portanto, essa afirmação está incorreta para hash. O CompTIA Security+ enfatiza que hash é unidirecional e não usa chaves, ao contrário da cifra.
- **Sempre encurta o texto pela metade:** Funções hash produzem uma saída de tamanho fixo, independentemente do tamanho da entrada. Por exemplo, SHA-256 sempre gera 256 bits (32 bytes). Não há uma regra de 'encurtar pela metade'; o tamanho do digest é constante e definido pelo algoritmo. Além disso, a função hash não é uma compressão simples; ela deve ser resistente a colisões e pré-imagem. Essa afirmação é tecnicamente falsa e não descreve uma propriedade de hash.
- **Precisa de par de chaves:** Funções hash não utilizam chaves. Elas são algoritmos públicos e determinísticos que mapeiam dados de entrada para um resumo. O uso de par de chaves é característico de criptografia assimétrica (como RSA ou ECC), não de hash. Embora hashes possam ser usados em conjunto com chaves em HMAC, a função hash em si não requer chaves. Portanto, essa opção está incorreta.

4) C — Criptografia assimétrica.

✓ **Por que está certa:** A alternativa correta é 'Criptografia assimétrica'. A criptografia assimétrica, também chamada de criptografia de chave pública, utiliza um par de chaves matematicamente relacionadas: uma chave pública, que pode ser distribuída livremente, e uma chave privada, mantida em segredo pelo proprietário. A chave pública é usada para cifrar dados ou verificar assinaturas digitais, enquanto a chave privada é usada para decifrar ou assinar. Exemplos incluem

RSA, ECC e Diffie-Hellman. A CompTIA Security+ exige o entendimento de que a assimetria resolve o problema de distribuição de chaves e fornece confidencialidade, integridade, autenticação e não repúdio.

✗ Por que as outras estão erradas:

- *Hashing*: Hashing é uma função criptográfica unidirecional que transforma uma entrada de tamanho variável em uma saída de tamanho fixo (digest). Não utiliza chaves e não é usada para cifrar/decifrar dados, mas sim para verificar integridade. A alternativa é incorreta porque hashing não envolve pares de chaves e não fornece confidencialidade.
- *Criptografia simétrica*: A criptografia simétrica usa uma única chave secreta compartilhada entre as partes para cifrar e decifrar. Exemplos: AES, DES, 3DES. Embora seja eficiente, não utiliza par de chaves pública e privada. A alternativa é incorreta porque descreve o modelo de chave única, não o modelo assimétrico.
- *Steganografia*: Steganografia é a arte de ocultar informações dentro de outros arquivos (imagens, áudios, vídeos) para que a existência da mensagem passe despercebida. Não envolve criptografia de chave pública ou privada. A alternativa é incorreta porque não é um método criptográfico baseado em chaves, mas sim uma técnica de ocultação.

5) A — Implementar a solução correspondente: CA assina o certificado — cadeia de confiança root CA → intermediária → leaf....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CA assina o certificado — cadeia de confiança root CA → intermediária → leaf.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: CSR = requisição de assinatura: contém a chave pública + identidade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CSR = requisição de assinatura: contém a chave pública + identidade.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: CRL/OCSP/stapling = como o browser checa se certificado foi revogado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): CRL/OCSP/stapling = como o browser checa se certificado foi revogado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'contains public key and identity, signed by CA' = certificate....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): 'contains public key and identity, signed by CA' = certificate.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'revocation checking method with online query' = OCSP....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): 'revocation checking method with online query' = OCSP.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado

✅ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Certificates): Cenário: 'usuário acessa o site e o cadeado vermelho diz que o certificado não é confiável' — self-signed ou expirado/revocado..

❌ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.